

**FACULDADE DE TECNOLOGIA SENAC RIO
TECNOLOGIA EM ANÁLISE E DESENVOLVIMENTO DE SISTEMAS**

**FRANCISCO GIULIANNIO DUARTE DA SILVA
ISABEL MARÇANO MOURA DA PAZ
LUCAS ALVES DA CRUZ
LUCAS MEIRELLES BARBOSA BORGES
MATHEUS EDSON BARBOSA TURSO**

**FUNÇÃO DO AUDITOR E TÉCNICAS DE AUDITORIA EM TECNOLOGIA DA
INFORMAÇÃO**

Estudo sobre o papel do auditor de Tecnologia da Informação, seus métodos de análise e sua contribuição para a segurança e governança dos sistemas

**RIO DE JANEIRO
2026**

FRANCISCO GIULIANNO DUARTE DA SILVA

ISABEL MARÇANO MOURA DA PAZ

LUCAS ALVES DA CRUZ

LUCAS MEIRELLES BARBOSA BORGES

MATHEUS EDSON BARBOSA TURSO

FUNÇÃO DO AUDITOR E TÉCNICAS DE AUDITORIA EM TECNOLOGIA DA INFORMAÇÃO

Estudo sobre o papel do auditor de Tecnologia da Informação, seus métodos de análise e sua contribuição para a segurança e governança dos sistemas

Relatório de pesquisa apresentado à Faculdade de Tecnologia Senac Rio, como parte dos requisitos para avaliação da unidade curricular Métricas e Auditoria de Software.

Orientador: Prof. José William Firmino Bezerra

RIO DE JANEIRO

2026

RESUMO

A auditoria de Tecnologia da Informação (TI) possui papel fundamental nas organizações modernas, auxiliando na identificação de riscos, avaliação de controles internos e melhoria dos processos tecnológicos. Este trabalho apresenta a função do auditor de TI, suas responsabilidades, as principais técnicas utilizadas durante uma auditoria e sua aplicação em ambientes organizacionais.

São abordados conceitos relacionados ao planejamento de auditoria, coleta de evidências, testes de controle, elaboração de relatórios e aplicação prática por meio de um estudo de caso fictício. Além disso, o trabalho apresenta uma análise crítica sobre as vantagens, limitações e desafios da auditoria de TI, bem como sua relação com o desenvolvimento de software.

A auditoria deixa de ser apenas uma atividade de verificação e passa a atuar como uma ferramenta estratégica para garantir segurança, eficiência, conformidade e melhoria contínua dos sistemas

.

Palavras-chave: Auditoria de TI; Auditor; Segurança da Informação; Controle Interno; Tecnologia.

REFERÊNCIAS

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. NBR ISO 19011:2018: Diretrizes para auditoria de sistemas de gestão. Rio de Janeiro: ABNT, 2018. Disponível em: <https://www.abntcatalogo.com.br/>

DAVIS, Chris; SCHILLER, Mike; WHEELER, Kevin. IT Auditing: Using Controls to Protect Information Assets. 2. ed. New York: McGraw-Hill, 2011.

THE INSTITUTE OF INTERNAL AUDITORS (IIA). International Standards for the Professional Practice of Internal Auditing. Lake Mary: The Institute of Internal Auditors. Disponível em: <https://www.theiia.org/>

ISACA. IT Audit and Assurance Standards and Guidelines. Schaumburg: ISACA. Disponível em: <https://www.isaca.org/resources/standards>

ISACA. COBIT Framework: Governance and Management Objectives. Schaumburg: ISACA. Disponível em: <https://www.isaca.org/resources/cobit>

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. ISO/IEC 27001: Information Security Management Systems — Requirements. Geneva: ISO. Disponível em: <https://www.iso.org/isoiec-27001-information-security.html>

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. ISO/IEC 27002: Information Security, Cybersecurity and Privacy Protection — Information Security Controls. Geneva: ISO. Disponível em: <https://www.iso.org/standard/75652.html>

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). Cybersecurity Framework (CSF) 2.0. Gaithersburg: NIST, 2024. Disponível em: <https://www.nist.gov/cyberframework>

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). Security and Privacy Controls for Information Systems and Organizations — SP 800-53 Revision 5. Gaithersburg: NIST, 2020. Disponível em: <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>

1 INTRODUÇÃO

A Tecnologia da Informação tornou-se um elemento essencial para o funcionamento das organizações, sendo utilizada para armazenar informações, automatizar processos e apoiar decisões estratégicas. Com essa crescente dependência dos sistemas digitais, surgem também novos riscos relacionados à segurança, disponibilidade e integridade das informações.

Nesse cenário, a auditoria de Tecnologia da Informação surge como uma prática responsável por avaliar sistemas, processos e controles tecnológicos, buscando identificar vulnerabilidades e garantir que os recursos de TI sejam utilizados de maneira adequada.

A atuação do auditor de TI não se limita apenas à identificação de falhas, mas envolve uma análise completa do ambiente tecnológico, considerando riscos, políticas internas, controles existentes e objetivos organizacionais.

Este trabalho tem como objetivo apresentar a função do auditor de Tecnologia da Informação, explicar as principais técnicas utilizadas em auditorias, demonstrar sua aplicação prática e analisar sua importância no desenvolvimento de sistemas seguros e eficientes.

2 DESENVOLVIMENTO

2.1 FUNDAMENTOS DA AUDITORIA DE TECNOLOGIA DA INFORMAÇÃO

2.1.1 Conceito de Auditoria de TI

A auditoria de Tecnologia da Informação é um processo sistemático de avaliação dos recursos tecnológicos de uma organização, com o objetivo de verificar se os sistemas, processos e controles estão funcionando corretamente.

Ela busca garantir que os recursos de tecnologia estejam protegidos, sejam utilizados de forma eficiente e estejam alinhados aos objetivos da empresa.

A auditoria envolve a análise de:

- sistemas;
- infraestrutura tecnológica;
- políticas internas;
- procedimentos;
- segurança da informação;
- controles internos.

Por meio dessa avaliação, é possível identificar riscos e propor melhorias para tornar os ambientes tecnológicos mais seguros e confiáveis.

2.1.2 Função do Auditor de Tecnologia da Informação

O auditor de TI é o profissional responsável por analisar, avaliar e fornecer recomendações sobre os recursos tecnológicos de uma organização.

Sua atuação envolve tanto aspectos técnicos quanto estratégicos, pois ele precisa compreender como a tecnologia influencia os processos de negócio.

Entre suas principais funções estão:

- avaliar controles internos;
- identificar riscos tecnológicos;

- verificar conformidade com normas e políticas;
- analisar segurança dos sistemas;
- coletar e avaliar evidências;
- elaborar relatórios de auditoria;
- sugerir melhorias.

O auditor deve atuar com independência e imparcialidade, garantindo que suas conclusões sejam baseadas em evidências e informações confiáveis.

2.1.3 Evolução do Papel do Auditor de TI

Inicialmente, a auditoria de sistemas era focada principalmente na conferência de registros e funcionamento básico dos sistemas.

Com o avanço da tecnologia, novas necessidades surgiram, como:

- proteção de dados;
- segurança cibernética;
- governança de TI;
- continuidade dos negócios;
- gerenciamento de riscos.

Dessa forma, o auditor deixou de ser visto apenas como um fiscalizador e passou a atuar como um profissional estratégico, contribuindo para a melhoria dos processos e para a tomada de decisões.

2.1.4 Importância da Auditoria nas Organizações

A auditoria de TI é importante porque permite que empresas identifiquem problemas antes que eles causem impactos maiores.

Entre seus benefícios estão:

- redução de riscos;
- melhoria dos controles internos;

- maior segurança das informações;
- aumento da confiabilidade dos sistemas;
- apoio à gestão.

Em um cenário marcado pela transformação digital, a auditoria tornou-se uma ferramenta essencial para garantir que a tecnologia continue contribuindo para os objetivos da organização.

2.2 PLANEJAMENTO E TÉCNICAS DE AUDITORIA

2.2.1 Planejamento da Auditoria de TI

O planejamento é uma das etapas mais importantes de uma auditoria, pois define a forma como o processo será conduzido e garante que a avaliação seja realizada de maneira organizada e eficiente.

Antes de iniciar uma auditoria, o auditor deve estabelecer:

- objetivos da auditoria;
- escopo da análise;
- recursos necessários;
- critérios de avaliação;
- riscos envolvidos.

Um planejamento adequado permite que o auditor compreenda o ambiente tecnológico analisado e determine quais áreas precisam de maior atenção.

Durante essa etapa também são definidos os procedimentos que serão utilizados para coletar informações e obter evidências confiáveis.

2.2.2 Definição de Objetivos e Escopo

O objetivo da auditoria representa aquilo que será avaliado, enquanto o escopo determina os limites da análise.

Exemplos de objetivos:

- verificar a segurança de um sistema;
- avaliar controles de acesso;
- analisar conformidade com políticas internas;
- identificar riscos tecnológicos.

O escopo pode incluir:

- sistemas específicos;
- bancos de dados;
- infraestrutura;
- processos internos;
- usuários e permissões.

A definição correta desses elementos evita que a auditoria fique muito ampla ou não consiga alcançar resultados relevantes.

2.2.3 Coleta de Evidências

A coleta de evidências consiste na obtenção de informações que serão utilizadas para fundamentar as conclusões da auditoria.

As evidências precisam ser:

- confiáveis;
- relevantes;
- suficientes;
- verificáveis.

Alguns exemplos de evidências são:

- documentos internos;
- registros de acesso;
- políticas de segurança;
- relatórios de sistemas;

- entrevistas com funcionários.

A partir dessas informações, o auditor consegue identificar problemas e avaliar se os controles existentes são eficientes.

2.2.4 Técnicas de Auditoria

As técnicas de auditoria são métodos utilizados pelo auditor para obter informações e analisar os processos tecnológicos.

Cada técnica possui um objetivo específico e pode ser aplicada conforme o tipo de auditoria realizada.

2.2.4.1 Entrevistas

A entrevista consiste na conversa entre o auditor e pessoas envolvidas nos processos analisados.

Ela tem como objetivo compreender:

- como as atividades são realizadas;
- quais procedimentos existem;
- quais dificuldades são encontradas.

Exemplo: O auditor entrevista o administrador do sistema para entender como usuários recebem permissões de acesso.

2.2.4.2 Análise Documental

A análise documental consiste na avaliação de documentos e registros existentes na organização.

Podem ser analisados:

- políticas internas;
- procedimentos;
- relatórios;
- contratos;
- registros de alterações.

Essa técnica permite comparar o que está documentado com o que realmente acontece na prática.

2.2.4.3 Observação In Loco

A observação in loco consiste no acompanhamento direto dos processos realizados pelos funcionários.

O objetivo é verificar se os procedimentos estão sendo executados conforme definido.

Exemplo: O auditor acompanha o processo de criação de usuários para verificar se existe aprovação antes da liberação de acesso.

2.2.4.4 Análise de Sistemas e Logs

Essa técnica envolve a análise dos registros gerados pelos sistemas.

Os logs podem apresentar informações como:

- acessos realizados;
- alterações feitas;
- tentativas de login;
- falhas ocorridas.

Esses dados ajudam a identificar comportamentos suspeitos e possíveis problemas de segurança.

2.2.4.5 Teste de Controle

Os testes de controle verificam se os mecanismos existentes realmente funcionam.

O auditor avalia se os controles são capazes de:

- prevenir problemas;
- identificar falhas;
- corrigir impactos.

Exemplo: Testar se um sistema bloqueia um usuário após várias tentativas incorretas de senha.

2.2.4.6 Relatório de Auditoria

Após realizar a análise, o auditor deve elaborar um relatório contendo os resultados encontrados.

Esse documento apresenta:

- objetivos da auditoria;
- procedimentos realizados;
- evidências coletadas;
- problemas identificados;
- recomendações.

O relatório serve como base para que a organização implemente melhorias e reduza riscos.

2.3 TÉCNICAS, CONTROLES E APLICAÇÃO PRÁTICA

2.3.1 Importância das Técnicas de Auditoria

As técnicas de auditoria permitem que o auditor obtenha informações suficientes para avaliar sistemas e processos.

Cada técnica contribui de uma maneira diferente, tornando a análise mais completa.

A combinação de várias técnicas aumenta a confiabilidade dos resultados e permite identificar riscos que poderiam passar despercebidos.

2.3.2 Tipos de Controles de Auditoria

Os controles são mecanismos utilizados pelas organizações para reduzir riscos e proteger seus recursos tecnológicos.

Eles podem ser classificados em três tipos:

2.3.2.1 Controles Preventivos

São controles criados para evitar que problemas aconteçam.

Exemplos:

- autenticação multifator;
- políticas de senha;
- restrições de acesso.

Seu objetivo é impedir falhas antes que elas ocorram.

2.3.2.2 Controles Detectivos

São controles responsáveis por identificar problemas ou eventos após sua ocorrência.

Exemplos:

- monitoramento de logs;
- alertas de segurança;
- sistemas de detecção.

Eles ajudam a encontrar rapidamente situações anormais.

2.3.2.3 Controles Corretivos

São aplicados após a ocorrência de um problema para reduzir impactos.

Exemplos:

- recuperação de backup;
- restauração de sistemas;
- correção de falhas.

2.3.3 Comparação entre Técnicas de Auditoria

Técnica	Objetivo	Exemplo
<i>Entrevista</i>	Obter informações dos envolvidos	Conversar com equipe de TI
<i>Análise documental</i>	Verificar registros formais	Avaliar políticas de segurança
<i>Observação</i>	Comparar prática e documentação	Acompanhar criação de usuários
<i>Análise de logs</i>	Identificar eventos do sistema	Verificar acessos suspeitos
<i>Teste de controle</i>	Avaliar funcionamento dos controles	Testar bloqueio de senha

2.3.4 Exemplos Práticos de Auditoria

2.3.4.1 Controle de Acesso

Uma empresa possui um sistema interno utilizado por diversos setores. Durante a auditoria, foi identificado que alguns funcionários tinham permissões maiores do que as necessárias.

O auditor aplicou:

- entrevista;
- análise documental;
- teste de controle.

Como melhoria, recomendou-se aplicar o princípio do menor privilégio, garantindo que cada usuário tenha somente os acessos necessários.

2.3.4.2 Backup de Dados

Uma organização realizava backups diariamente, porém nunca verificava se os arquivos poderiam ser recuperados. O auditor identificou o risco de perda permanente de informações. Como recomendação, foi sugerida a realização de testes periódicos de restauração.

2.3.4.3 Monitoramento de Segurança

Uma empresa possuía registros de acessos, mas não realizava análise frequente dos logs. O auditor identificou que atividades suspeitas poderiam passar despercebidas. A recomendação foi criar uma rotina de acompanhamento dos registros.

2.3.5 Revisão dos Conceitos Técnicos

Conceito	Definição
Auditoria de TI	Avaliação dos sistemas e processos tecnológicos
Auditor	Profissional responsável pela análise e recomendações
Evidência	Informação usada para comprovar conclusões
Controle interno	Medida criada para reduzir riscos
Risco tecnológico	Possibilidade de falha afetar sistemas ou dados
Teste de controle	Avaliação da eficiência dos controles

2.4 ESTUDO DE CASO: APLICAÇÃO DA AUDITORIA DE TI

2.4.1 Contexto da Empresa e Sistema Avaliado

Para demonstrar a aplicação prática dos conceitos estudados, foi desenvolvido um cenário fictício envolvendo a empresa TequiNova Soluções Digitais Ltda.

A empresa atua no desenvolvimento de softwares corporativos para outras organizações e utiliza sistemas internos para armazenar informações importantes, como:

- dados de clientes;
- informações financeiras;
- contratos;
- documentos técnicos;
- registros de atendimento.

Com o crescimento da empresa, novos funcionários foram adicionados ao sistema, porém os controles de acesso não acompanharam esse crescimento, criando possíveis riscos relacionados à segurança das informações. Diante dessa situação, a empresa solicitou uma auditoria interna de Tecnologia da Informação para avaliar seus controles e identificar possíveis vulnerabilidades.

2.4.2 Problema Identificado

Durante a auditoria, foram identificados alguns problemas relacionados ao gerenciamento de acessos e segurança do sistema.

2.4.2.1 Permissões excessivas de usuários

Alguns funcionários possuíam acesso a informações que não eram necessárias para suas atividades.

Isso aumentava o risco de:

- exposição de dados;
- alterações indevidas;
- uso inadequado das informações.

2.4.2.2 Ausência de revisão periódica dos acessos

A empresa não realizava verificações frequentes dos usuários cadastrados. Como consequência:

- funcionários antigos mantinham permissões;
- usuários que mudaram de função continuavam com acessos anteriores.

2.4.2.3 Falta de monitoramento dos registros

Embora o sistema gerasse logs de acesso, eles não eram analisados regularmente. Isso dificultava identificar:

- tentativas de acesso indevido;
- atividades suspeitas;
- alterações não autorizadas.

2.4.3 Processo de Auditoria Aplicado

2.4.3.1 Planejamento

Inicialmente foram definidos:

Objetivo: Avaliar a segurança do sistema e verificar a eficiência dos controles de acesso.

Escopo:

- cadastro de usuários;
- permissões;

- autenticação;
- registros de acesso.

2.4.3.2 Coleta de Evidências

Foram coletadas informações por meio de:

- entrevistas;
- análise documental;
- observação dos processos;
- testes de controle.
- Avaliação dos Controles

Após a coleta de informações, o auditor analisou se os controles existentes eram suficientes para reduzir os riscos identificados.

2.4.3.3 Avaliação dos Controles

Após a coleta de informações, o auditor analisou se os controles existentes eram suficientes para reduzir os riscos identificados.

2.4.4 Ferramentas e Técnicas Utilizadas

Foram utilizadas as seguintes técnicas:

2.4.4.1 Entrevistas

Realizadas com:

- equipe de TI;
- gestores;
- administradores do sistema.

Objetivo: Compreender como os acessos eram criados e gerenciados.

2.4.4.2 Análise Documental

Foram avaliados:

- políticas de segurança;
- registros de usuários;
- permissões;
- procedimentos internos.

Foi identificado que alguns documentos estavam desatualizados.

2.4.4.3 Observação In Loco

O auditor acompanhou o processo real de criação de usuários. Foi identificado que novos acessos foram liberados sem aprovação formal.

2.4.4.3 Testes de Controle

Foram realizados testes para verificar:

- usuários inativos;
- permissões inadequadas;
- funcionamento dos registros.

2.4.5 Resultados Encontrados

Após a auditoria, foram encontrados os seguintes resultados:

Problema identificado	Risco gerado
Permissões excessivas	Acesso indevido a informações
Falta de revisão de acessos	Usuários com privilégios desnecessários

Logs não monitorados	Dificuldade de identificar incidentes
Políticas desatualizadas	Falta de padronização

A auditoria concluiu que os controles existentes precisavam ser fortalecidos.

2.4.6 Sugestões de Melhoria

Foram recomendadas as seguintes ações:

- Aplicação do princípio do menor privilégio: Cada usuário deve possuir somente os acessos necessários para sua função.
- Revisão periódica de permissões: A empresa deve revisar acessos regularmente para remover permissões antigas.
- Implementação de autenticação multifator: Adicionar uma camada extra de proteção para reduzir riscos de acesso indevido.
- Monitoramento dos logs: Criar uma rotina de análise dos registros para detectar comportamentos suspeitos.
- Atualização das políticas internas: Revisar procedimentos relacionados à criação e remoção de usuários.

2.5 ANÁLISE CRÍTICA DA AUDITORIA DE TI

2.5.1 Vantagens da Auditoria de TI

A auditoria de TI apresenta diversos benefícios para as organizações. Entre eles estão:

- Redução de riscos: A auditoria permite identificar vulnerabilidades antes que causem impactos maiores.
- Melhoria dos controles internos: Avalia se os mecanismos existentes realmente protegem os sistemas.
- Maior confiabilidade das informações: Garante maior segurança, integridade e disponibilidade dos dados.

- Apoio à tomada de decisão: Os relatórios produzidos ajudam gestores a tomar decisões baseadas em evidências.

2.5.2 Limitações Existentes

Apesar dos benefícios, existem algumas limitações.

- Dependência das evidências: A qualidade da auditoria depende das informações disponíveis. Caso os registros estejam incompletos, a análise pode ser prejudicada.
- Complexidade tecnológica: Sistemas modernos possuem grande complexidade, dificultando uma análise completa.
- Necessidade de atualização constante: O auditor precisa acompanhar novas tecnologias e ameaças digitais.

2.5.3 Desafios na Prática

Alguns desafios encontrados são:

- resistência dos colaboradores;
- dificuldade de acesso às informações;
- mudanças constantes nos sistemas;
- necessidade de profissionais especializados.

Além disso, é necessário equilibrar segurança e produtividade, pois controles muito rígidos podem dificultar o funcionamento dos processos.

2.5.4 Custos e Dificuldades de Implementação

A implementação de auditorias pode exigir investimentos em:

- profissionais capacitados;
- ferramentas especializadas;
- treinamentos;

- melhorias tecnológicas.

Apesar disso, esses custos podem evitar prejuízos causados por falhas de segurança, perda de dados e interrupções dos serviços.

2.5.5 Aplicação Atual nas Empresas

Atualmente, a auditoria de TI é utilizada em áreas como:

- segurança da informação;
- governança tecnológica;
- proteção de dados;
- computação em nuvem;
- desenvolvimento de software.

Com o crescimento da transformação digital, sua importância aumentou devido ao aumento dos riscos tecnológicos.

2.5.6 Comparação com Outras Abordagens

Abordagem	Característica
Auditoria de TI	Avalia processos, controles e riscos tecnológicos
Pentest	Busca encontrar vulnerabilidades técnicas
Monitoramento contínuo	Acompanha sistemas em tempo real
Auditoria tradicional	Foca em processos e documentos gerais

2.6 AUDITORIA DE TI NO DESENVOLVIMENTO DE SOFTWARE

2.6.1 Relação entre Auditoria e Desenvolvimento de Software

A auditoria de TI está diretamente relacionada ao desenvolvimento de software, pois permite avaliar se sistemas estão sendo criados de forma segura e eficiente.

O auditor pode acompanhar todas as etapas do ciclo de desenvolvimento, garantindo que riscos sejam identificados desde o início.

2.6.2 Atuação do Auditor no Ciclo de Vida do Software

Planejamento

Avalia:

- objetivos do sistema;
- riscos;
- requisitos de segurança.

Requisitos

Verifica se as necessidades dos usuários estão corretamente definidas.

Desenvolvimento

Analisa:

- boas práticas de programação;
- controle de versões;
- segurança do código.

Testes

Avalia se:

- falhas foram encontradas;
- correções foram aplicadas;
- controles funcionam.

Implantação

Verifica:

- autorização de mudanças;
- configuração do ambiente;
- controle de acesso.

Manutenção

Acompanha:

- atualizações;
- correções;
- novos riscos.

2.6.3 Importância da Auditoria no Software

A auditoria contribui para:

- softwares mais seguros;
- redução de vulnerabilidades;
- melhoria da qualidade;
- maior confiabilidade dos sistemas.

Dessa forma, o auditor atua de forma preventiva, evitando que problemas sejam descobertos apenas após a implantação do sistema.

3 CONCLUSÃO

A auditoria de Tecnologia da Informação é uma ferramenta essencial para garantir a segurança, qualidade e eficiência dos sistemas organizacionais. O auditor possui uma atuação estratégica, contribuindo para prevenção de riscos, avaliação de controles e melhoria contínua dos processos.

Por meio das técnicas de auditoria, é possível identificar vulnerabilidades, analisar evidências e propor soluções adequadas. Além disso, sua aplicação no desenvolvimento de software reforça a importância de criar sistemas seguros desde as primeiras etapas do projeto.

Mesmo diante de desafios como custos, complexidade tecnológica e necessidade de atualização constante, a auditoria continua sendo indispensável para organizações que dependem da tecnologia.